BRIEFING · THURSDAY 22 OCTOBER 2026

php2shell

Two critical flaws in PHP, the engine under most of the web. One fix. What we actually know, and what to do.

evidence as of 11:34 UTC | 144 sources captured | every fact linked



severity, both flaws

IF YOU READ ONE SLIDE

The bottom line

01

Patch, then restart

PHP 8.5.12, 8.4.27, 8.3.36 or 8.2.35. A fix that is installed but not restarted is not running.

CONFIRMED

02

Trying is not breaking in

Millions of attack attempts. No organisation has confirmed a break-in.

REPORTED

03

Decide ”offline” now

The agencies disagree on what to do if you cannot patch. Name who decides, before you need it.

CONFIRMED

Sources: php.net, Matthew Prince, Cloudflare CEO on..., CISA, NCSC UK

ON ONE PAGE

The situation at a glance

9.2
severity out of 10, both flaws

4
fixed versions, out 21 Oct

millions
attack attempts at one CDN

0
confirmed break-ins

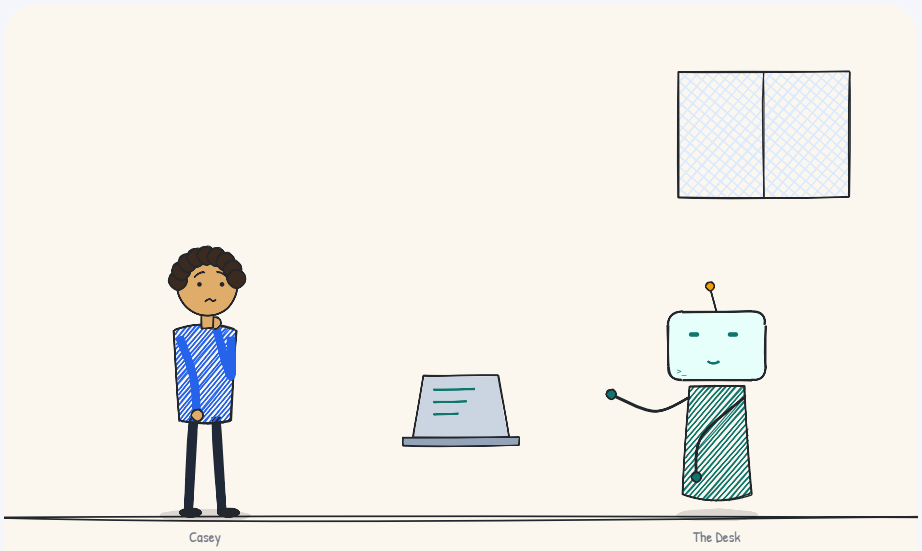
16
agencies compared

10
organisations offline, reported

Sources: php.net, Matthew Prince, Cloudflare CEO on..., CISA

A STRIP

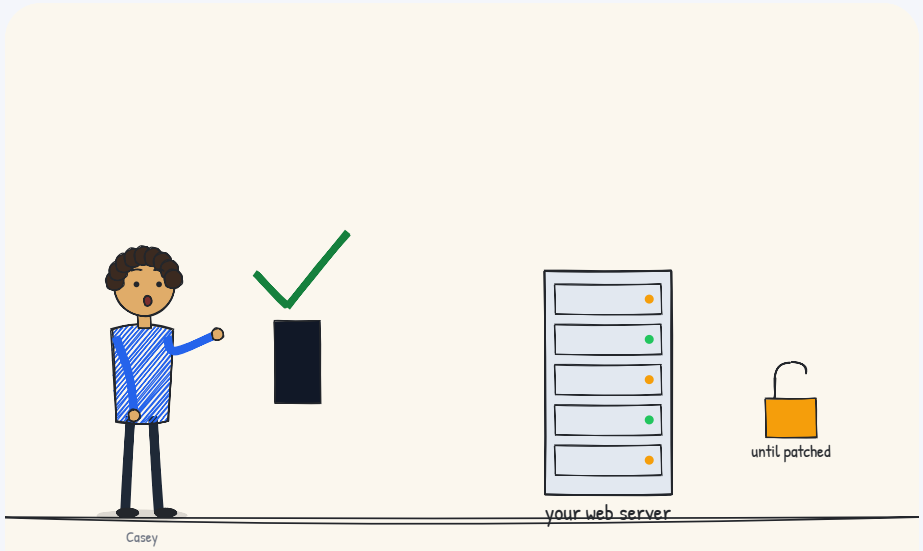
Casey runs a website



THE QUESTION

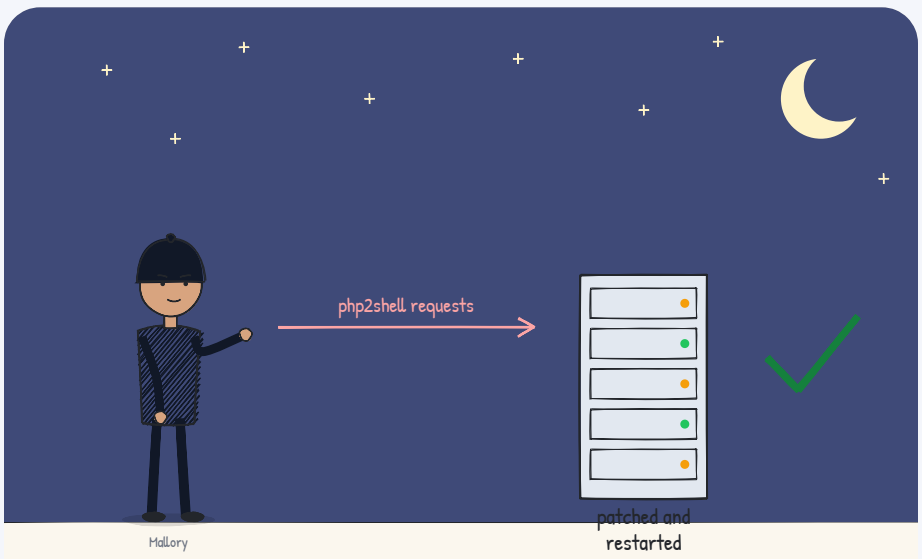
Casey: The radio says websites are going offline. Is mine?

The Desk: Let me show you what is confirmed first.



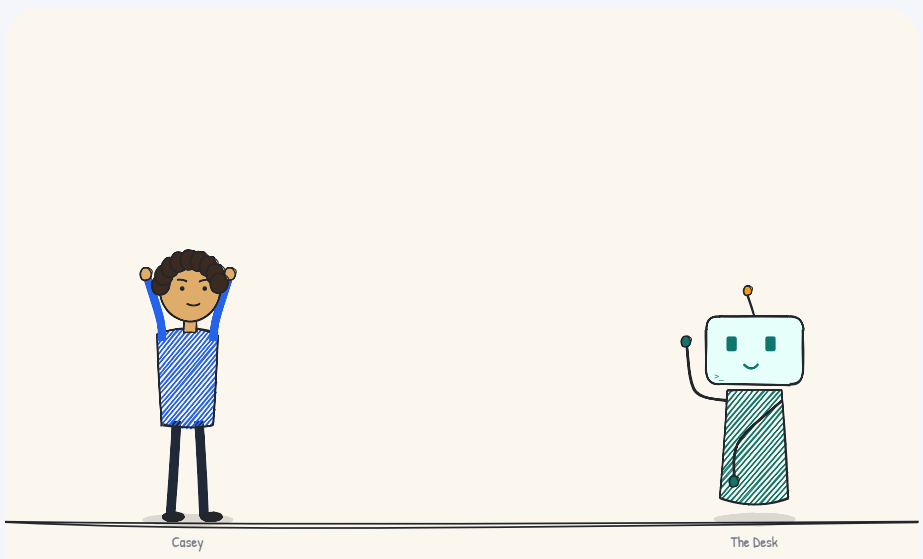
WHERE THE HOLE IS

Casey: So not my phone?



ATTACKERS ARE TRYING

Mallory: Knock knock. Millions of times.



Update PHP. Restart it. Ask your host to confirm both.

From the storyboard Where it stands, 22 October. The lines are the storyboard's own words, not quotes.

Sources: php.net, Matthew Prince, Cloudflare CEO on..., CISA

WHAT IT IS

Two holes in the engine itself

Not in WordPress or a plugin: in PHP, underneath every site that runs on it.



CVSS v4.0, critical, both flaws

1. **Anyone on the internet**
2. **one web request, no password**
3. **the PHP engine, before any app code**
4. **the server runs their commands**

CONFIRMED Proven on Apache mod_php with default settings.

DISPUTED On PHP-FPM, sources disagree.

CONFIRMED Phones and laptops are not the target: web servers are.

TWO YEARS IN FIVE MOMENTS

Noticed in 2024. Fixed in a day.

2024

An audit spots the weakness. Nobody can show it is exploitable, so it is left.

22 MONTHS LATER

Aug 2026

Three teams using AI turn it into working attacks within three weeks.

10 WEEKS LATER

20 Oct

It leaks: the CVE numbers circulate two days early, with a wrong score.

1 DAY LATER

21 Oct

PHP ships the fix a day early. Firewall rules are already live.

1 DAY LATER

22 Oct

Agencies: update, or take it offline. Sites go dark as a precaution.

Sources: PHP Foundation, Calif, php.net, BBC News

20 TO 22 OCTOBER, HOUR BY HOUR

The race

Attackers on the left. Defenders on the right. Times in UTC.



Sources: PHP Foundation, THN, Cloudflare, php-src, NSA Cyber on X

EXPOSED IS NOT EXPLOITED

From ”70% of the internet” to zero

~70%	of websites use PHP	REPORTED
2.6M	hosts expose PHP to the internet	REPORTED
1.57M	still unpatched on 21 Oct	REPORTED
millions	attack attempts, at one CDN	REPORTED
0	confirmed break-ins	CONFIRMED
?	hit, and holding something worth reaching	UNVERIFIED

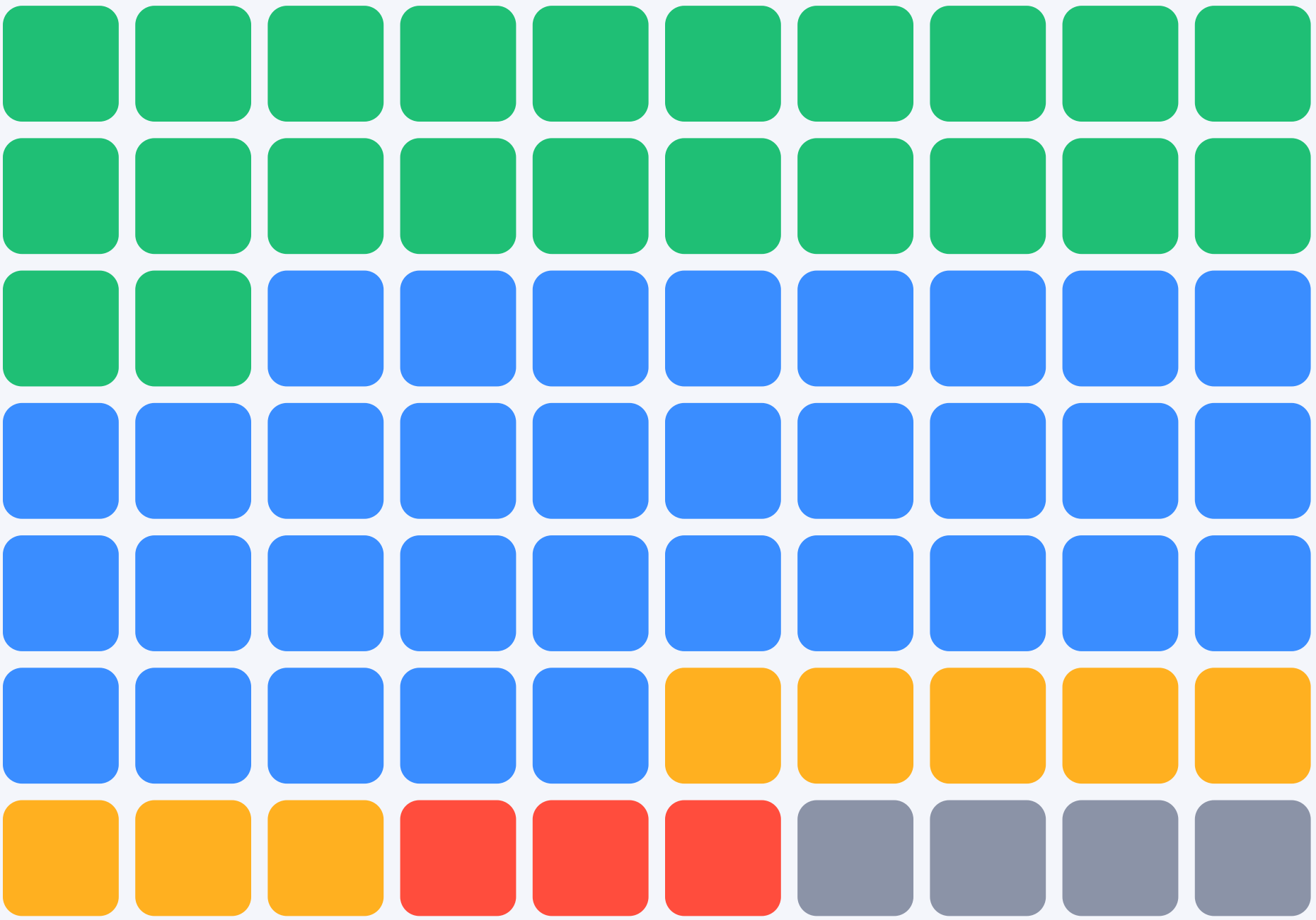
Each line is a different count by a different party. The one that matters, nobody has measured.

Sources: Cloudflare, THN, SecurityWeek, Matthew Prince, Cloudflare CEO on..., CISA

HOW SURE ARE WE?

70 statements, checked

Each square is one statement this site tracks, coloured by how well it is supported.



22 **Confirmed** two or more original sources agree

33 **Reported** one party says so

8 **Disputed** sources disagree

3 **Contradicted** a source shows it false

4 **Unverified** nobody could check

16 GOVERNMENT CYBER AGENCIES

Same fix. Five answers to "and if we can't?"

16 of 16 say: install the fix now.

2 Take it offline

US NSA Cybersecurity · **US** CISA

2 Offline as a last resort

UK NCSC · **CH** BACS (NCSC)

3 Isolate it from the internet

EU CERT-EU · **FR** CERT-FR (ANSSI) · **CA** CCCS

1 Restrict access

LV CERT.LV

6 Say nothing about it

EU ENISA CSIRTs Network · **AU** ASD's ACSC · **NZ** NCSC · **NL** NCSC-NL · **IT** ACN / CSIRT Italia · **JP** JPCERT/CC

2 Could not be read

ES CCN-CERT · **PT** CNCS

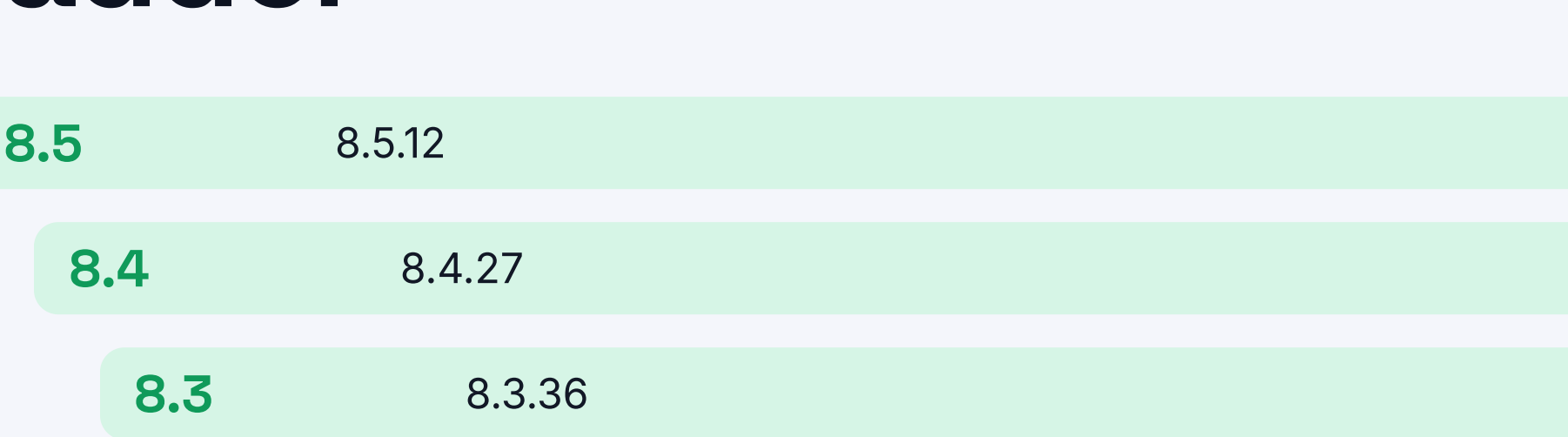
Sources: NSA Cyber on X, CISA, NCSC UK, CERT-EU, CERT-FR

WHO GETS A FIX

The fix climbs down a ladder

8.5	8.5.12
8.4	8.4.27
8.3	8.3.36
8.2	8.2.35
8.1, 8.0	source backport, no release
7.4	mitigation commit only
7.3 to 5.x	nothing

724 products built on PHP in the Dutch NCSC list



The product curve runs to 15:28 UTC on 22 October, after the 11:34 capture.

Sources: php.net, php-src, NCSC-NL

HOW CLOSE TO LOG4SHELL?

Four rungs up a seven-rung ladder

7	Ransomware, botnets	not yet, no evidence
6	On CISA's exploited list	not yet
5	One-command module	not yet, PR open, not merged
4	Mass scanning	reached, fingerprinting
3	Public exploit code	reached, mostly broken
2	Used before the patch	reached, one honeypot hit
1	Private exploits	reached, Aug 2026

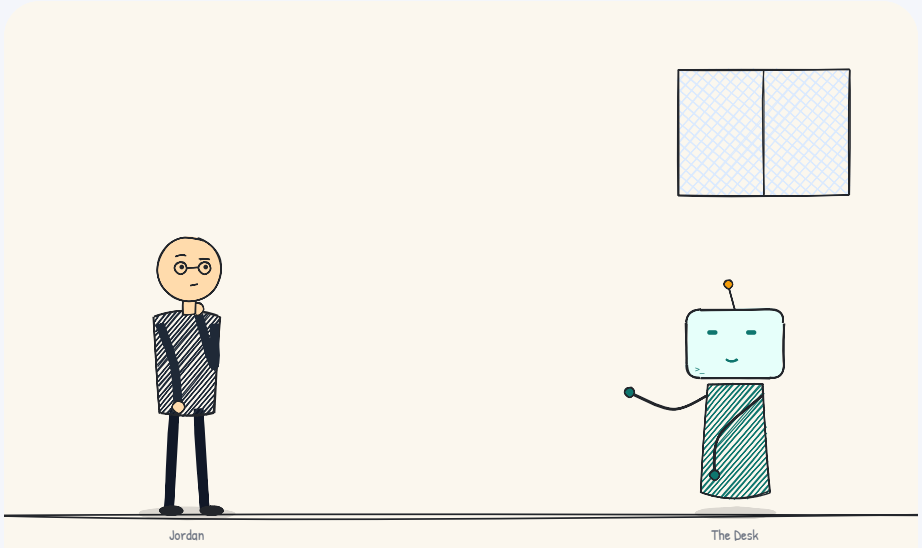
Both earlier PHP flaws on that list ended up with ransomware.

From the cyber desk's reading at 17:51 UTC on 22 October, after the 11:34 capture.

Sources: Calif, Amazon, Sansec, CISA, CVE record

A STRIP

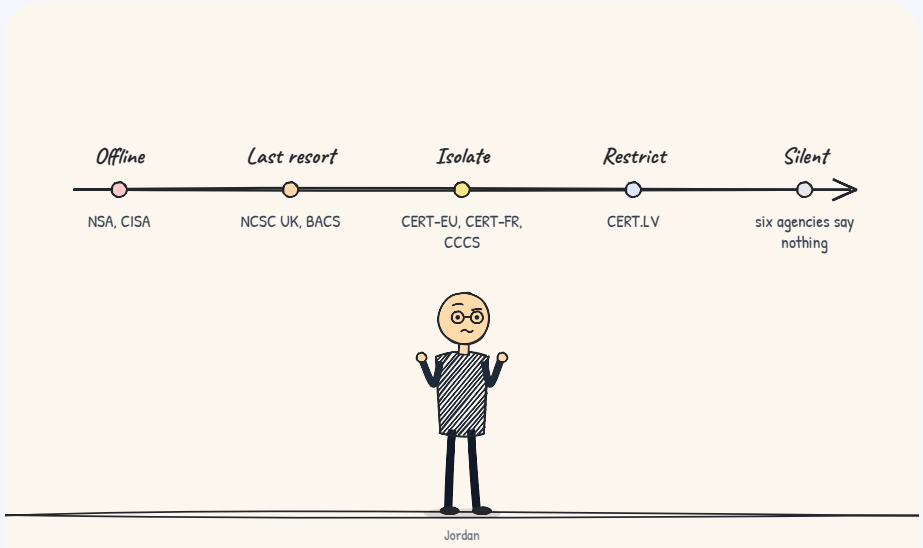
Jordan sits on the board



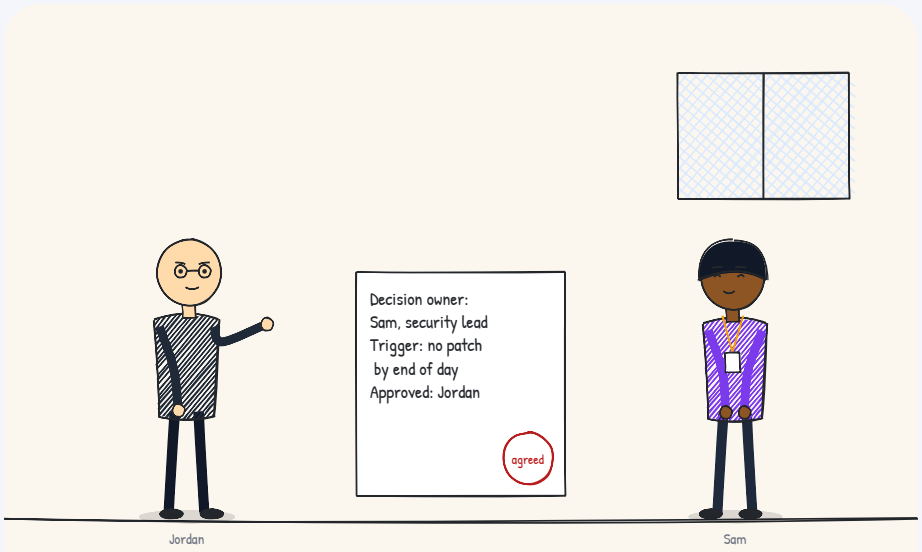
EVERYONE AGREES ON ONE THING

Jordan: What do the governments say?

The Desk: Every one: install the fix.



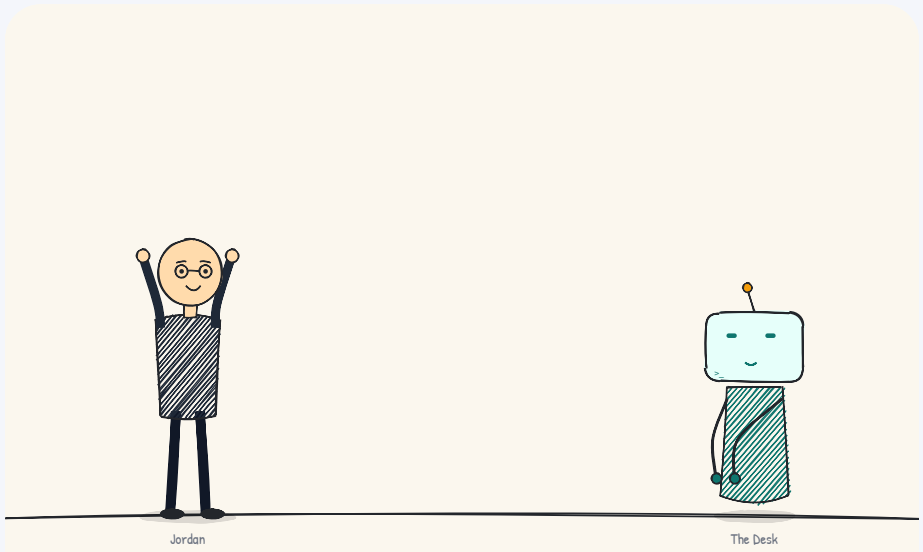
AND IF YOU CANNOT INSTALL IT TODAY?



THE QUESTION FOR THE BOARD

Jordan: Who here can pull a system offline tonight?

Sam: Me, if you write it down now.



Same fix everywhere. Decide offline before you need it.

From the storyboard What the agencies say. The lines are the storyboard's own words, not quotes.

STATED, NOT PAPERED OVER

What nobody knows yet

? Whether any website was actually broken into before it installed the fix.

? Whether the fix is complete. A report on 21 October suggested it may not be; the PHP project has not answered it publicly yet.

? Who leaked the news on 20 October, and where.

? Exactly which websites went offline, and why. Most of the list comes from one news live page and has not been confirmed by the organisations named.

? Where the 70% figure comes from. None of the pages that use it says how it was measured.

WHAT TO DO

By who you are



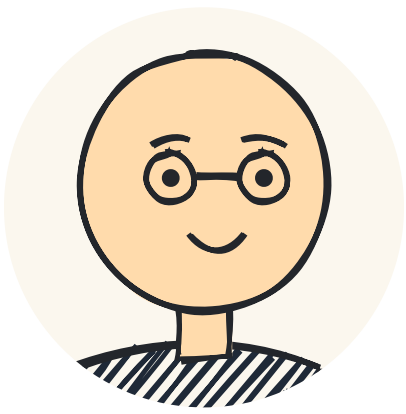
You run a website

- Ask your host which PHP version is serving your site right now
- and when it was last restarted



You run the servers

- Patch and restart every PHP process
- Cannot today: temporary settings, an edge rule, then offline
- Watch for PHP workers starting shells



You own the risk

- Name who can take a system offline
- Ask for evidence you were not hit
- Find anything still on PHP 8.1 or older

CHECK EVERY LINE

Every fact links to a saved copy of its source

144
web pages saved as evidence

857
files hashed

70
statements with a status

16
agencies compared

1
a web page

2
captured, hashed

3
the evidence vault

4
a claim with a status

5
graded by the fact-check desk

6
this page, every fact linked

Built by a team of software agents for one editor. Research and stories, every source captured, dated and hashed.

php.oct.2026.newsroom.sgit.ai